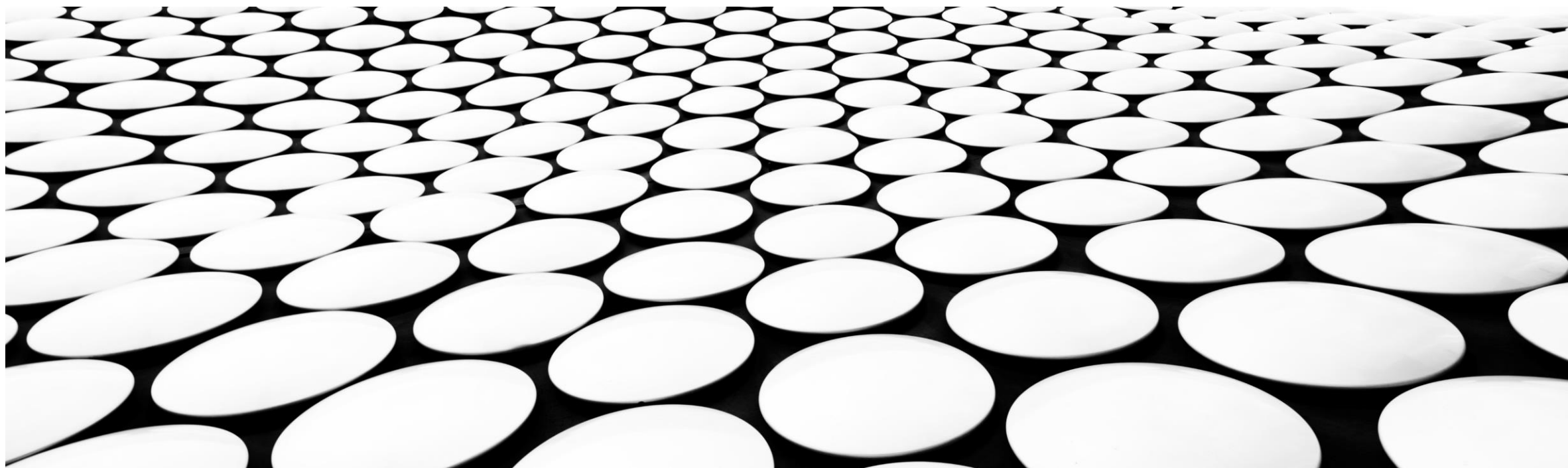


雲端網站防禦專案

使用 AWS SHIELD STANDARD WAF + 自建工具



架構圖



說明

Region: Oregon

專案：
官網 www.hannstar.com

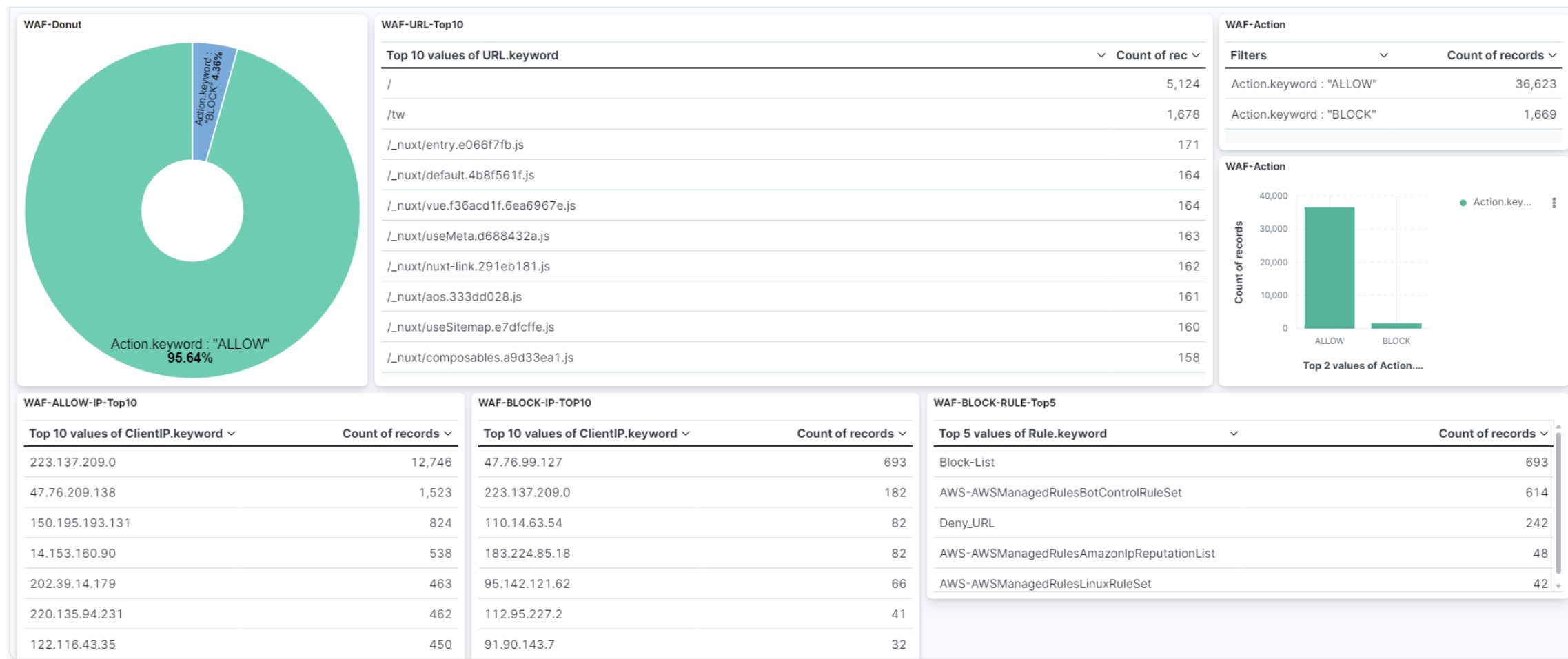
方案：
1. 使用 ELK 收取 WAF Log，統計 IP 連線數後手動封鎖
2. 使用 Wazuh 收取 nginx log，透過 內建 Rules 判斷攻擊行為後自動封鎖

Region: Tokyo

專案：
公司多個 *.hannstar.com 對外保護

方案：
使用 Graylog 收取 WAF Log，統計 IP 連線數後告警

官網WAF – ELK 可視化 DASHBOARD



目的：WAF 防禦成效分析

功能：TOP 10 允許IP & 拒絕 IP，與拒絕原因總覽

官網 WAZUH DASHBOARD

W.

Dashboards

Hannstar - Nginx Log 儀表板

Full screen

Share

Clone

Reporting

 [Edit](#)

3

②

DQL

Last 7 days

[Show dates](#)

Refresh

[⊕ Add filter](#)

風險：6

[警] 中風險數目(8~11)

[警] 高風險數目(>12) ⓘ

Nginx log 數目

Count

Count

500
0

熱點地圖

Level >= 5 [用來查全部]

1-50 of 5227

< 1 2 3 4 5 ... 10 >

Time	rule.level	data.srcip	data.protocol	data.id	data.url	agent.name	rule.description	full
> Sep 10, 2025 @ 10:42:17.244	5	216.221.221.235	GET	404	/en/news/financial/	Official-AL2023-prd01	Web server 400 error code.	216.221.235.0/Sep 5:10:00 /en/news/financial/TP/1.43821 "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/115.0"
> Sep 10, 2025 @ 10:21:54.122	5	172.21.90.229	GET	404	/news/%E8%BF%91%E6%9C%9F%E7%99%8C%E7%8F%8E%E6%9C%AC%E5%85%AC%E5%8F%B8%E5%AD%90%E5%85%AC%E5%8F%B8%E8%A2%A8%E4%B8%8D%E8%82%96%E4%BA%8A%E5%A9%A0%E5%9A%A0	Official-AL2023-prd01	Web server 400 error code.	172.21.90.229/Sep 2:08:21 "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/115.0"
> Sep 10, 2025 @ 10:07:40.065	5	203.126.139.200	GET	404	/_nuxt/builds/meta/af798cd7-e1d7-4986-a4b5-76c96d7b3d11.json	Official-AL2023-prd-09092025	Web server 400 error code.	203.126.139.200/Sep 5:10:00 /_nuxt/builds/meta/af798cd7-e1d7-4986-a4b5-76c96d7b3d11.json
> Sep 10, 2025 @ 09:53:26.559	5	172.21.90.82	GET	404	/news/%E8%BF%91%E6%9C%9F%E7%99%8C%E7%8F%8E%E6%9C%AC%E5%85%AC%E5%8F%B8%E5%AD%90%E5%85%AC%E5%8F%B8%E8%A2%A8%E4%B8%8D%E8%82%96%E4%BA%8A%E5%A9%A0%E5%9A%A0	Official-AL2023-prd01	Web server 400 error code.	172.21.90.82/Sep 5:10:00 /news/%E8%BF%91%E6%9C%9F%E7%99%8C%E7%8F%8E%E6%9C%AC%E5%85%AC%E5%8F%B8%E5%AD%90%E5%85%AC%E5%8F%B8%E8%A2%A8%E4%B8%8D%E8%82%96%E4%BA%8A%E5%A9%A0%E5%9A%A0

熱點地圖

官網WAF – Team主動推送 (WAF防禦)

定時掃描結果概覽

VirusTotal 每小時 Action:ALLOW - Top10 檢查

告警等級：正常 

IP地址: 136.226.229.16 數量: 579 是否惡意: False 發現的引擎數量: 0
IP地址: 120.219.57.103 數量: 305 是否惡意: False 發現的引擎數量: 0
IP地址: 45.76.122.71 數量: 125 是否惡意: True 發現的引擎數量: 2
IP地址: 45.76.44.221 數量: 119 是否惡意: True 發現的引擎數量: 4
IP地址: 103.14.141.200 數量: 113 是否惡意: False 發現的引擎數量: 0
IP地址: 141.164.48.161 數量: 112 是否惡意: False 發現的引擎數量: 0
IP地址: 167.172.175.168 數量: 108 是否惡意: False 發現的引擎數量: 0
IP地址: 209.97.171.44 數量: 105 是否惡意: False 發現的引擎數量: 0
IP地址: 101.9.194.67 數量: 100 是否惡意: False 發現的引擎數量: 0
IP地址: 165.22.122.238 數量: 85 是否惡意: True 發現的引擎數量: 1

目的：WAF 放行的 IP , 再次確認安全性

功能：通過的 TOP-10 IP 傳送至 Virustotal
情資檢查

定時掃描結果概覽

VirusTotal 每小時 Action:ALLOW - Top10 檢查

告警等級：警告 

IP地址: 114.136.111.107 數量: 445 是否惡意: False 發現的引擎數量: 0
IP地址: 120.237.81.195 數量: 436 是否惡意: False 發現的引擎數量: 0
IP地址: 114.34.184.108 數量: 363 是否惡意: False 發現的引擎數量: 0
IP地址: 39.9.226.46 數量: 277 是否惡意: False 發現的引擎數量: 0
IP地址: 185.119.0.206 數量: 210 是否惡意: True 發現的引擎數量: 1
IP地址: 65.154.226.170 數量: 186 是否惡意: True 發現的引擎數量: 8
IP地址: 35.184.34.71 數量: 184 是否惡意: False 發現的引擎數量: 0
IP地址: 112.175.250.218 數量: 183 是否惡意: False 發現的引擎數量: 0
IP地址: 185.119.0.215 數量: 181 是否惡意: False 發現的引擎數量: 0
IP地址: 27.50.59.146 數量: 114 是否惡意: True 發現的引擎數量: 1

目的：訊息強調化，可快速訊息瀏覽

功能：若引擎數 > 7 , 數量 > 1000則紅字標示，並變更告警等級

官網WAF – Team主動推送 (WAF防禦)

查詢高風險 IP (引擎數 >7) 七天內出現數目

VirusTotal 高風險 IP 檢查

告警等級：分析     

高風險IP比對: 195.170.172.128

DATE:2024-11-23,出現條(小時/天)數: 0, 連線總數: 0

DATE:2024-11-22,出現條(小時/天)數: 0, 連線總數: 0

DATE:2024-11-21,出現條(小時/天)數: 0, 連線總數: 0

DATE:2024-11-20,出現條(小時/天)數: 0, 連線總數: 0

DATE:2024-11-19,出現條(小時/天)數: 0, 連線總數: 0

DATE:2024-11-18,出現條(小時/天)數: 0, 連線總數: 0

DATE:2024-11-17,出現條(小時/天)數: 0, 連線總數: 0

Important: You must update your Webhook URL for this connection in Teams. [Learn more about this update](#)

目的：自動歷史查詢七天內出現次數

功能：若引擎數 >7, 則將該 IP 自動反查七天內的歷史，協助管理員判定是否加入黑名單

WAF Block 行為告警 (15 分鐘內)

15分鐘內 AWS WAF 拒絕數量上限值

告警等級：警告     

目前數目：5171 > 警戒數目：200

目的：高拒絕數時，應主動介入查看狀態

功能：WAF 總阻擋數 > 200 告警

官網WAF – Team主動推送 (WAF防禦)

WAF ALLOW 行為告警 (15 分鐘內)

15分鐘內 AWS ALLOW 允許數量上限值

告警等級：警告 ⚡ ⚡ ⚡ ⚡ ⚡

目前數目：152 > 警戒數目：100

TOP 3 連線

IP: 49.234.3.160, 數目：101, 國家：China

IP: 85.193.0.175, 數目：45, 國家：Czechia

IP: 95.217.176.173, 數目：43, 國家：Finland

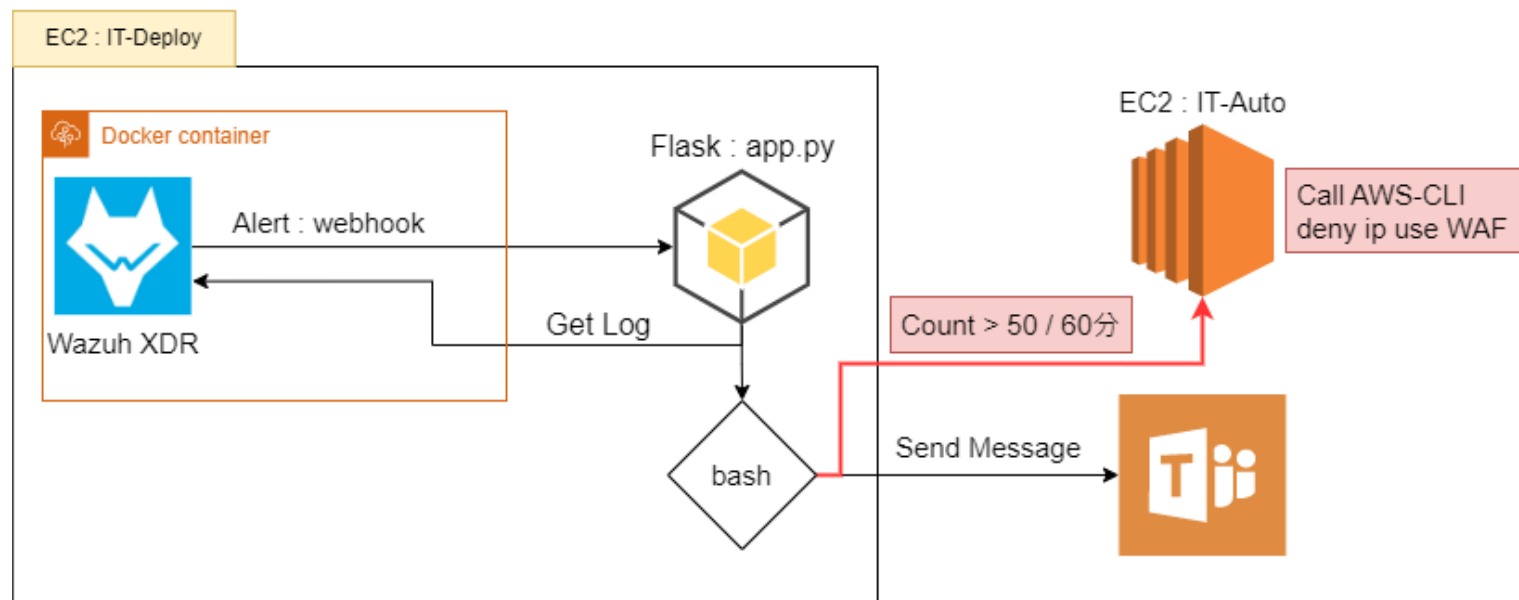
Important: You must update your Webhook URL for this connecti
Teams. [Learn more about this update](#)

目的：加強高連線時判斷

功能：加入 GeoIP 資料庫，自動判斷前 3
連線的 IP 來源國家，協助管理者判
斷是否加入黑名單

透過WAZUH 內建 RULE 判別攻擊行為

Wazuh 自動呼叫 WAF 封鎖 IP 架構圖



當 Wazuh 發現大量 http code: 40x 時

- 1.觸發 Alert 中的 webhook 與發送 Teams
- 2.Webhook 呼叫 app.py 去 Query Opensearch 抓取 1 小時內的 TOP10 排名
- 3.TOP10 數量大於 50 的，呼叫 bash 內的 awscli 指令，將 IP 加入預設好的 Blocklist set 中，這樣 WAF 就會進行封鎖動作

官網WAF - WAZUH 主動封鎖

Wazuh Nginx 風險 IP (60分鐘內)

Wazuh Scanning

告警等級：警告 ⚡⚡⚡⚡⚡

訊息內容：

[Condition] 條件：『level >= 7』 && 『data_id = 404/405』 && 『IP上限值 = 1』 60分鐘內的 Alert messages °

[Summary] 共找到筆數：1

=====

有來源 IP 的警報數量大於 1 次，列出出現頻率最高的前 10 名：

[IP] 8.34.210.44 : 27 次

[IP] 34.68.34.87 : 20 次

[IP] 34.68.34.80 : 1 次

[IP] 34.68.34.92 : 1 次

[IP] 34.68.34.94 : 1 次

Wazuh Nginx 風險 IP (60分鐘內)

Wazuh Scanning

告警等級：危險 🔥🔥🔥🔥🔥

訊息內容：

[Condition] 條件：『level >= 7』 && 『data_id = 404/405』 && 『IP上限值 = 1』 60分鐘內的 Alert messages °

[Summary] 共找到筆數：16

=====

有來源 IP 的警報數量大於 1 次，列出出現頻率最高的前 10 名：

[IP] 34.68.34.85 : 143 次 [Block]

[IP] 34.68.34.74 : 50 次 [Block]

[IP] 34.68.34.84 : 40 次

[IP] 34.68.34.83 : 26 次

[IP] 8.34.210.55 : 25 次

[IP] 34.68.34.88 : 22 次

[IP] 34.68.34.93 : 16 次

[IP] 34.68.34.67 : 15 次

[IP] 8.34.210.42 : 11 次

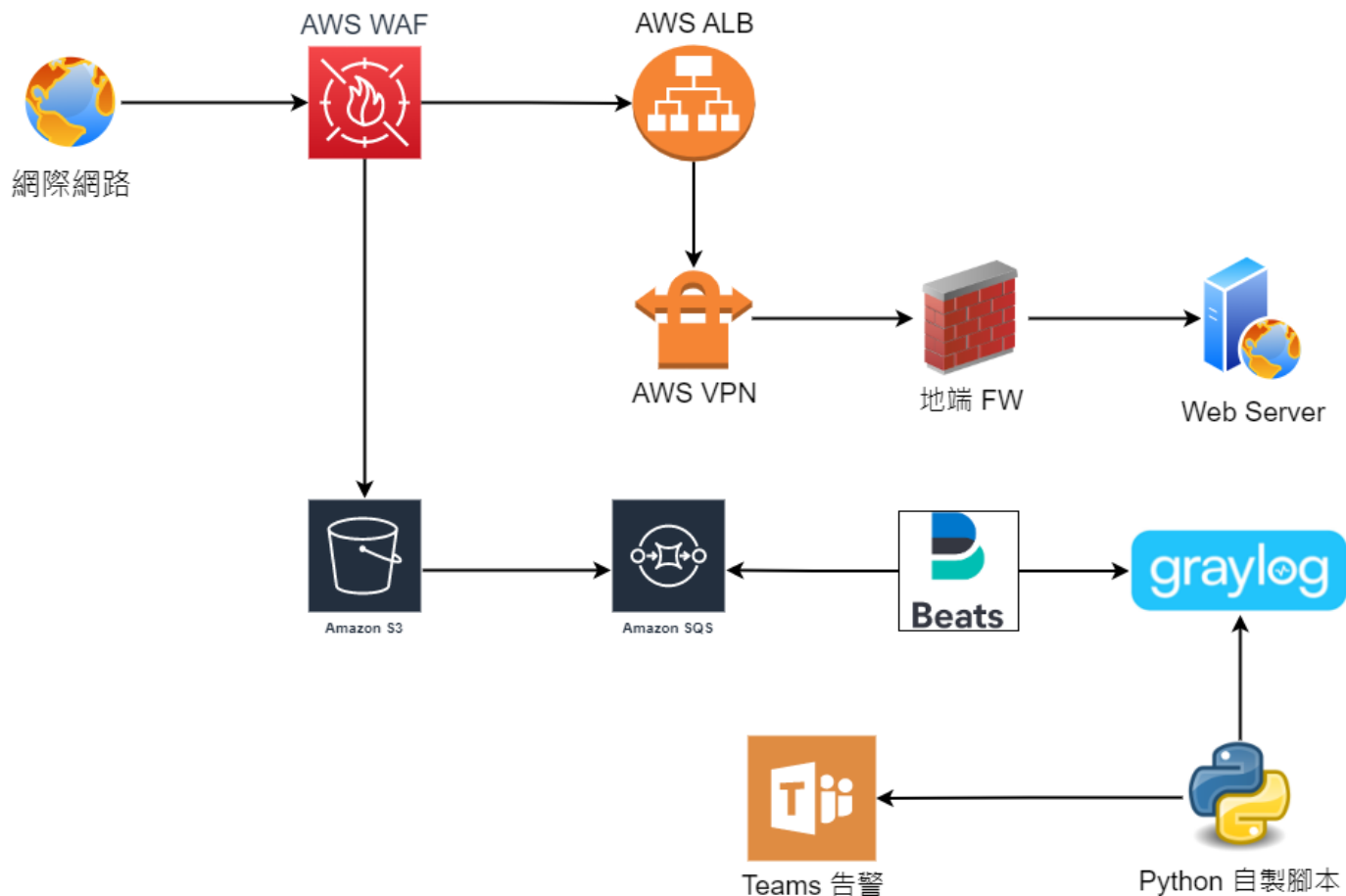
[IP] 34.68.34.92 : 11 次

條件：Level > 7 & http_code:40x

- 1.未滿閾值 50，告警等級：警告
- 2.超過閾值 50
 - (1) 告警等級：危險
 - (2) 字眼 Block 提示
 - (3) IP 加入 WAF 封鎖 Set

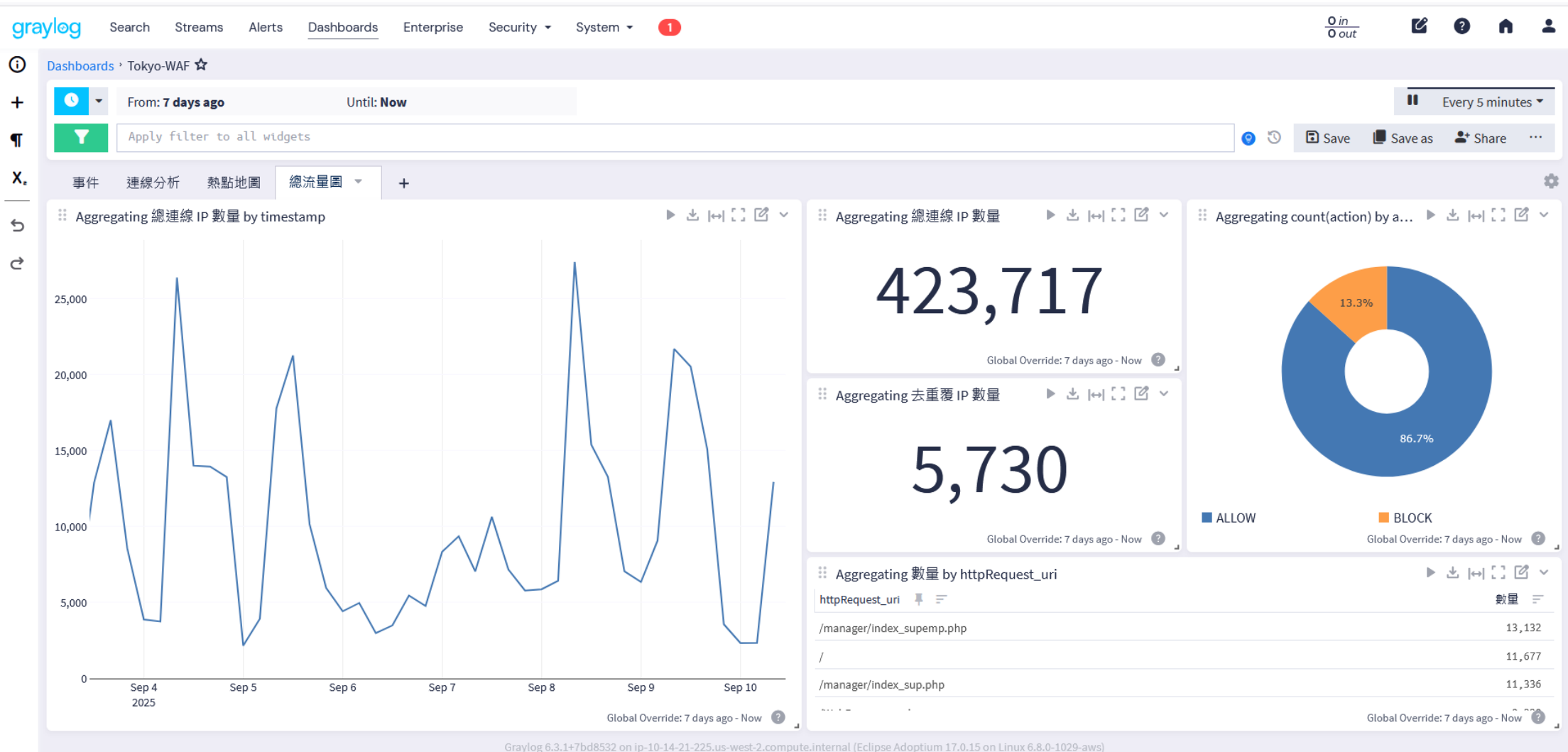
收取 LOG 與告警

AWS WAF 在 Tokyo 區的監控方案



1. WAF Log 會存到 S3 Bucket，同時會丟一份到 SQS 內
2. 使用 FileBeat 去收取 SQS 內的 Log，並拋給 GrayLog
3. GrayLog 建立 Dashboard
4. Python 串連 Teams (如下圖)
 - (1) 每 15 分鐘確認總連線數是否超過 2500
 - (2) 超過 2500 時，列出核心網站 15 分鐘內的連線數
 - (3) 每小時提供 TOP10 報告

TOKYO GRAYLOG DASHBOARD



TOKYO WAF - 告警



未知的使用者 下午 02:06

新增

[Tokyo Region] 定時掃描結果概覽

[Tokyo Region] WAF 每小時 Action:ALLOW - Top10 報告

告警等級：正常    

來源國家：Taiwan, IP: 211.20.101.197, 數量: 626

來源國家：Taiwan, IP: 106.104.113.57, 數量: 276

來源國家：Taiwan, IP: 60.250.205.2, 數量: 217

來源國家：Taiwan, IP: 61.216.115.88, 數量: 212

來源國家：Japan, IP: 2.57.215.181, 數量: 159

來源國家：Taiwan, IP: 111.249.5.173, 數量: 152

來源國家：United States, IP: 205.169.39.94, 數量: 147

來源國家：Taiwan, IP: 203.69.91.103, 數量: 145

來源國家：China, IP: 222.92.211.130, 數量: 138

來源國家：Taiwan, IP: 219.87.129.190, 數量: 137



回覆



未知的使用者 下午 02:45

新增

[Tokyo Region] WAF ALLOW 行為告警 (15 分鐘內)

15分鐘內 AWS ALLOW 允許數量上限值

告警等級：警告    

目前數目：2559 > 警戒數目：2500

TOP3 連線

IP:123.51.236.48, Count:419, Country:Taiwan

IP:113.88.147.252, Count:349, Country:China

IP:211.75.88.126, Count:347, Country:Taiwan



未知的使用者 下午 01:31

[Tokyo Region] 通知管理者資訊

[Tokyo Region] 核心網站連線數 (15 分鐘內)

告警等級：警告     

 com : 272 hits (past hour) [宏]

 com : 219 hits (past hour)

 com : 9 hits (past hour)

 com : 65 hits (past hour)

 com : 141 hits (past hour)

 com : 72 hits (past hour)

 .com : 0 hits (past hour)

 .org : 3 hits (past hour)



跟 Orgeon 不同處，是 Orgeon 會參考 Wazuh 自動封鎖，Tokyo 這邊只會在訊息內，提供負責人的姓名